CYBERSRS

Secure University API Access Management

Software Requirements Specification

DRAFT — human review required

Version 3 • 2026-10-30T04:13:08.476392+00:00

AI-generated advisory document. Review by a qualified professional is required.

Automated checks do not prove completeness or semantic correctness. SDLC suitability scores are rule-based points, not probabilities.

Content SHA-256: cfb9919f383f83217b70b1d6cdb9be8d50bb178c6d53887d9e1dfa9823dd7500

Contents

1. Introduction 3

2. Functional requirements 4

3. Non-functional requirements 9

4. Security, privacy and compliance 12

5. Data requirements 12

6. Network and interfaces 12

7. Compliance and policy applicability matrix 12

8. Architecture 12

9. Threats 15

10. Risks 17

11. User stories and use cases 20

12. Verification and acceptance 21

13. Glossary 26

14. SDLC recommendation and workflow 26

SDLC rankings and decision evidence 32

Evidence register 34

Source references 34

Validation findings 36

Human review history 36

AI drafting record 36

Requirements traceability matrix 37

1. Introduction

Original project description

Design a secure university API access management system that controls access to internal APIs used by student portals, administrative applications, research systems, and campus services. Authorized administrators should be able to register APIs, define access permissions, approve or revoke application access, and review active API clients. The system should authenticate API clients, enforce role- or policy-based access, detect repeated failed authentication and unauthorized API requests, generate security alerts, and maintain audit logs of access decisions, permission changes, and administrator actions. The platform should provide a centralized dashboard, integrate with existing university identity services, support multiple campus locations, and remain secure, reliable, scalable, and manageable.

Summary: This specification records the project purpose, stakeholder constraints and unresolved decisions stated in the source evidence below.

Items

Stakeholder source statement E-001

Detail: Design a secure university API access management system that controls access to internal APIs used by student portals, administrative applications, research systems, and campus services.

Status: confirmed

Evidence ids: E-001

Stakeholder source statement E-002

Detail: Authorized administrators should be able to register APIs, define access permissions, approve or revoke application access, and review active API clients.

Status: confirmed

Evidence ids: E-002

Stakeholder source statement E-003

Detail: The system should authenticate API clients, enforce role- or policy-based access, detect repeated failed authentication and unauthorized API requests, generate security alerts, and maintain audit logs of access decisions, permission changes, and administrator actions.

Status: confirmed

Evidence ids: E-003

Stakeholder source statement E-004

Detail: The platform should provide a centralized dashboard, integrate with existing university identity services, support multiple campus locations, and remain secure, reliable, scalable, and manageable.

Status: confirmed

Evidence ids: E-004

2. Functional requirements

Applicability reason: Independent source obligations; unspecified choices remain TBD.

Requirements

FR-001 - control access to internal APIs used by student portals, administrative applications, research systems, and campus services

Statement: The system shall control access to internal APIs used by student portals, administrative applications, research systems, and campus services.

Rationale: Source obligation E-001_O01.

Priority: must

Dimensions: business; security

Basis: explicit

Evidence ids: E-001

Acceptance criteria

Given: the system receives a request to access an internal API through a student portal, administrative application, research system, or campus service

When: the system evaluates the request against defined access policies and applies role-based restrictions

Then: the system returns a response indicating whether access is granted or denied based on the requester's authenticated identity and authorized roles

Method: test

Observable evidence: External test capture of the resulting response

FR-002 - allow Authorized administrators to register APIs

Statement: The system shall allow Authorized administrators to register APIs.

Rationale: Source obligation E-002_O01.

Priority: should

Dimensions: business

Basis: explicit

Evidence ids: E-002

Acceptance criteria

Given: Authorized administrators register APIs

When: initiate the registration of a new API endpoint

Then: the newly registered API is available in the access management system for use

Method: test

Observable evidence: External test capture of the resulting response

FR-003 - allow Authorized administrators to define access permissions

Statement: The system shall allow Authorized administrators to define access permissions.

Rationale: Source obligation E-002_O02.

Priority: should

Dimensions: business; security

Basis: explicit

Evidence ids: E-002

Acceptance criteria

Given: Authorized administrators define access permissions

When: define a policy for a named API resource

Then: the named policy definition is available for examination in the system interface

Method: inspection

Observable evidence: External test capture of the inspection record

FR-004 - allow Authorized administrators to approve or revoke application access

Statement: The system shall allow Authorized administrators to approve or revoke application access.

Rationale: Source obligation E-002_O03.

Priority: should

Dimensions: business; security

Basis: explicit

Evidence ids: E-002

Acceptance criteria

Given: Authorized administrators approve or revoke application access

When: approve a request for application access

Then: the approved decision is observed in the request status field

Method: demonstration

Observable evidence: External test capture of the resulting state

FR-005 - allow Authorized administrators to review active API clients

Statement: The system shall allow Authorized administrators to review active API clients.

Rationale: Source obligation E-002_O04.

Priority: should

Dimensions: business

Basis: explicit

Evidence ids: E-002

Acceptance criteria

Given: Authorized administrators review active API clients

When: request a list of currently active API clients

Then: the requested list of active API clients is returned for examination

Method: analysis

Observable evidence: External test capture of the resulting response

FR-006 - authenticate API clients

Statement: The system shall authenticate API clients.

Rationale: Source obligation E-003_O01.

Priority: should

Dimensions: business; security

Basis: explicit

Evidence ids: E-003

Acceptance criteria

Given: the system receives a controlled identity fixture as a principal for API client authentication

When: the system submits the principal to authenticate

Then: the system either accepts or rejects the authentication based on the fixture's validity

Method: test

Observable evidence: External test capture of the resulting response

FR-007 - enforce role- or policy-based access

Statement: The system shall enforce role- or policy-based access.

Rationale: Source obligation E-003_O02.

Priority: should

Dimensions: business; security

Basis: explicit

Evidence ids: E-003

Acceptance criteria

Given: the system receives a controlled role or policy permission fixture

When: the system evaluates access based on that fixture

Then: the requested access is allowed or denied in accordance with the fixture's defined permissions

Method: test

Observable evidence: External test capture of the resulting state

FR-008 - detect repeated failed authentication

Statement: The system shall detect repeated failed authentication.

Rationale: Source obligation E-003_O03.

Priority: should

Dimensions: business; security

Basis: explicit

Evidence ids: E-003

Acceptance criteria

Given: the system receives a controlled sequence of failed authentication attempts

When: the system processes the repeated failures

Then: the system identifies the condition of repeated failed authentication

Method: test

Observable evidence: External test capture of the resulting state

Unresolved decisions: Decision Q-66ec7b6022bf is TBD.

FR-009 - detect unauthorized API requests

Statement: The system shall detect unauthorized API requests.

Rationale: Source obligation E-003_O04.

Priority: should

Dimensions: business

Basis: explicit

Evidence ids: E-003

Acceptance criteria

Given: the system receives a controlled unauthorized API request

When: the system processes the request

Then: the system identifies that the request is unauthorized

Method: test

Observable evidence: External test capture of the resulting state

Unresolved decisions: Decision Q-66ec7b6022bf is TBD.

FR-010 - generate security alerts

Statement: The system shall generate security alerts.

Rationale: Source obligation E-003_O05.

Priority: should

Dimensions: business; security

Basis: explicit

Evidence ids: E-003

Acceptance criteria

Given: an alert condition is initiated using a controlled event fixture

When: the system detects and responds to the condition

Then: a security alert exists in the system as a result of the triggered condition

Method: demonstration

Observable evidence: External test capture of the inspection record

FR-011 - maintain audit logs of access decisions, permission changes, and administrator actions

Statement: The system shall maintain audit logs of access decisions, permission changes, and administrator actions.

Rationale: Source obligation E-003_O06.

Priority: should

Dimensions: business; security; auditability; data

Basis: explicit

Evidence ids: E-003

Acceptance criteria

Given: the system records access decisions, permission changes, and administrator actions using a controlled fixture

When: the system maintains logs for these events

Then: audit logs contain entries reflecting those events as they occur

Method: inspection

Observable evidence: External test capture of the inspection record

Unresolved decisions: Decision Q-3aae42e94793 is TBD.; Decision Q-64ef2e28335c is TBD.

FR-012 - provide a centralized dashboard

Statement: The system shall provide a centralized dashboard.

Rationale: Source obligation E-004_O01.

Priority: should

Dimensions: business

Basis: explicit

Evidence ids: E-004

Acceptance criteria

Given: a user accesses the dashboard named in the source obligation

When: the system opens the dashboard as a controlled user

Then: the dashboard is displayed or available for use

Method: test

Observable evidence: External test capture of the resulting response

FR-013 - integrate with existing university identity services

Statement: The system shall integrate with existing university identity services.

Rationale: Source obligation E-004_O02.

Priority: should

Dimensions: business; integration

Basis: explicit

Evidence ids: E-004

Acceptance criteria

Given: a user initiates an exchange with the external identity service named in the source obligation

When: the system performs the interoperation as defined by the source obligation

Then: the system observes successful interoperation with that service

Method: test

Observable evidence: External test capture of the resulting response

FR-014 - support multiple campus locations

Statement: The system shall support multiple campus locations.

Rationale: Source obligation E-004_O03.

Priority: should

Dimensions: business

Basis: explicit

Evidence ids: E-004

Acceptance criteria

Given: a user initiates use from each campus location named in the source obligation

When: the system supports the use as defined by the source obligation

Then: use succeeds at each location

Method: test

Observable evidence: External test capture of the resulting state

3. Non-functional requirements

Applicability reason: Independent source obligations; unspecified choices remain TBD.

Requirements

NFR-001 - be secure

Statement: The system shall be secure.

Rationale: Source obligation E-001_O02.

Priority: must

Dimensions: security

Basis: explicit

Evidence ids: E-001

Acceptance criteria

Given: A draft acceptance plan for this quality goal: the system shall be secure against unauthorized access and data exfiltration via API endpoints.

When: An analyst inspects or reviews that acceptance plan to determine whether measurable targets are defined or remain TBD.

Then: The plan's measurable targets remain TBD or unconfirmed, as no specific thresholds, attack scenarios, or success/failure criteria are provided in the draft plan.

Method: inspection

Observable evidence: External test capture of the inspection record

Unresolved decisions: Decision Q-7b2e5f89a0b1 is TBD.

NFR-002 - remain secure

Statement: The system shall remain secure.

Rationale: Source obligation E-004_O04.

Priority: should

Dimensions: security

Basis: explicit

Evidence ids: E-004

Acceptance criteria

Given: The system shall remain secure under all conditions of use.

When: An analyst inspects or reviews that acceptance plan.

Then: The plan's measurable targets remain TBD or unconfirmed.

Method: inspection

Observable evidence: External test capture of the resulting response

Unresolved decisions: Decision Q-7b2e5f89a0b1 is TBD.

NFR-003 - remain reliable

Statement: The system shall remain reliable.

Rationale: Source obligation E-004_O05.

Priority: should

Dimensions: availability

Basis: explicit

Evidence ids: E-004

Acceptance criteria

Given: The system shall remain reliable under all conditions of use.

When: An analyst inspects or reviews that acceptance plan.

Then: The plan's measurable targets remain TBD or unconfirmed.

Method: inspection

Observable evidence: External test capture of the resulting state

Unresolved decisions: Decision Q-819bb986f419 is TBD.

NFR-004 - remain scalable

Statement: The system shall remain scalable.

Rationale: Source obligation E-004_O06.

Priority: should

Dimensions: performance

Basis: explicit

Evidence ids: E-004

Acceptance criteria

Given: The system shall remain scalable under all conditions of use.

When: An analyst inspects or reviews that acceptance plan.

Then: The plan's measurable targets remain TBD or unconfirmed.

Method: inspection

Observable evidence: External test capture of the inspection record

Unresolved decisions: Decision Q-543394346815 is TBD.

NFR-005 - remain manageable

Statement: The system shall remain manageable.

Rationale: Source obligation E-004_O07.

Priority: should

Dimensions: usability

Basis: explicit

Evidence ids: E-004

Acceptance criteria

Given: The system shall remain manageable under all conditions of use.

When: An analyst inspects or reviews that acceptance plan.

Then: The plan's measurable targets remain TBD or unconfirmed.

Method: inspection

Observable evidence: External test capture of the resulting state

Unresolved decisions: Decision Q-5268b96e41b0 is TBD.

Related requirement ids: FR-001; FR-006; FR-007; FR-008; FR-009; FR-010; FR-011; FR-012; FR-013; FR-014

4. Security, privacy and compliance

Applicability reason: Existing canonical requirements, where applicable, are linked below; this section adds no separate obligation. Unresolved stakeholder decisions remain open.

Related requirement ids: FR-001; FR-003; FR-004; FR-006; FR-007; FR-008; FR-009; FR-010; FR-011; NFR-001; NFR-002

5. Data requirements

Applicability reason: Existing canonical requirements, where applicable, are linked below; this section adds no separate obligation. Unresolved stakeholder decisions remain open.

Related requirement ids: FR-011

6. Network and interfaces

Applicability reason: Existing canonical requirements, where applicable, are linked below; this section adds no separate obligation. Unresolved stakeholder decisions remain open.

7. Compliance and policy applicability matrix

Open decisions: Decision Q-66ec7b6022bf is TBD.; Decision Q-66cf5513b374 is TBD.

8. Architecture

Summary: Proposed logical components and interactions mapped to canonical source obligations.

Items

Actor: Authorized administrators

Detail: Proposed logical endpoint for the source-stated actor: Authorized administrators.

Status: proposed

Evidence ids: E-002

Requirement ids: FR-002; FR-003; FR-004; FR-005

Component name: Actor: Authorized administrators

Responsibility: Represent the source-stated actor: Authorized administrators.

API Access Control Engine

Detail: Proposed logical owner for FR-001, FR-006, FR-007, FR-008, FR-009, FR-010, FR-014, NFR-001, NFR-002, NFR-003, NFR-004, NFR-005.

Status: proposed

Evidence ids: E-001; E-003; E-004

Requirement ids: FR-001; FR-006; FR-007; FR-008; FR-009; FR-010; FR-014; NFR-001; NFR-002; NFR-003; NFR-004; NFR-005

Component name: API Access Control Engine

Responsibility: The system shall control access to internal APIs used by student portals, administrative applications, research systems, and campus services. The system shall authenticate API clients. The system shall enforce role- or policy-based access. The system shall detect repeated failed authentication. The system shall detect unauthorized API requests. The system shall generate security alerts. The system shall support multiple campus locations. The system shall be secure. The system shall remain secure. The system shall remain reliable. The system shall remain scalable. The system shall remain manageable.

Administrator Interface Module

Detail: Proposed logical owner for FR-002, FR-003, FR-004, FR-005, FR-014, NFR-001, NFR-002, NFR-003, NFR-004, NFR-005.

Status: proposed

Evidence ids: E-001; E-002; E-004

Requirement ids: FR-002; FR-003; FR-004; FR-005; FR-014; NFR-001; NFR-002; NFR-003; NFR-004; NFR-005

Component name: Administrator Interface Module

Responsibility: The system shall allow Authorized administrators to register APIs. The system shall allow Authorized administrators to define access permissions. The system shall allow Authorized administrators to approve or revoke application access. The system shall allow Authorized administrators to review active API clients. The system shall support multiple campus locations. The system shall be secure. The system shall remain secure. The system shall remain reliable. The system shall remain scalable. The system shall remain manageable.

Audit and Logging Service

Detail: Proposed logical owner for FR-011, FR-014, NFR-001, NFR-002, NFR-003, NFR-004, NFR-005.

Status: proposed

Evidence ids: E-001; E-003; E-004

Requirement ids: FR-011; FR-014; NFR-001; NFR-002; NFR-003; NFR-004; NFR-005

Component name: Audit and Logging Service

Responsibility: The system shall maintain audit logs of access decisions, permission changes, and administrator actions. The system shall support multiple campus locations. The system shall be secure. The system shall remain secure. The system shall remain reliable. The system shall remain scalable. The system shall remain manageable.

Centralized Dashboard

Detail: Proposed logical owner for FR-012, FR-014, NFR-001, NFR-002, NFR-003, NFR-004, NFR-005.

Status: proposed

Evidence ids: E-001; E-004

Requirement ids: FR-012; FR-014; NFR-001; NFR-002; NFR-003; NFR-004; NFR-005

Component name: Centralized Dashboard

Responsibility: The system shall provide a centralized dashboard. The system shall support multiple campus locations. The system shall be secure. The system shall remain secure. The system shall remain reliable. The system shall remain scalable. The system shall remain manageable.

Identity Integration Layer

Detail: Proposed logical owner for FR-013, FR-014, NFR-001, NFR-002, NFR-003, NFR-004, NFR-005.

Status: proposed

Evidence ids: E-001; E-004

Requirement ids: FR-013; FR-014; NFR-001; NFR-002; NFR-003; NFR-004; NFR-005

Component name: Identity Integration Layer

Responsibility: The system shall integrate with existing university identity services. The system shall support multiple campus locations. The system shall be secure. The system shall remain secure. The system shall remain reliable. The system shall remain scalable. The system shall remain manageable.

Data flows

Proposed source-defined interaction

Detail: Proposed directed path for FR-002, FR-003, FR-004, FR-005.

Status: proposed

Evidence ids: E-002

Requirement ids: FR-002; FR-003; FR-004; FR-005

From component: Actor: Authorized administrators

To component: Administrator Interface Module

Data or action: The system shall allow Authorized administrators to register APIs. The system shall allow Authorized administrators to define access permissions. The system shall allow Authorized administrators to approve or revoke application access. The system shall allow Authorized administrators to review active API clients.

Trust boundaries

Proposed source-defined trust boundary

Detail: Proposed logical trust-domain crossing for FR-002, FR-003, FR-004, FR-005.

Status: proposed

Evidence ids: E-002

Requirement ids: FR-002; FR-003; FR-004; FR-005

Untrusted component: Actor: Authorized administrators

Trusted component: Administrator Interface Module

Enforcement: The system shall allow Authorized administrators to register APIs. The system shall allow Authorized administrators to define access permissions. The system shall allow Authorized administrators to approve or revoke application access. The system shall allow Authorized administrators to review active API clients.

9. Threats

Threats

Id: THR-001

Asset: User identities and authenticated access

Actor: Hypothetical attacker, privileged insider or failure cause

Scenario: Derived hypothesis: An attacker uses a compromised identity or authenticated session to impersonate an authorized user and exercise that user's permitted operations.

Impact: Unauthorized use of a legitimate identity could expose resources or alter system state.

Control requirement ids: FR-006; FR-007; FR-008; FR-009; FR-010; FR-011; FR-012; FR-013; FR-014; NFR-002; NFR-003; NFR-004; NFR-005

Evidence ids: E-003; E-004

Residual risk: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

Id: THR-002

Asset: Role and permission boundaries

Actor: Hypothetical attacker, privileged insider or failure cause

Scenario: Derived hypothesis: A principal exploits an incorrect role assignment or permission check to perform operations outside the source-defined authorization boundary.

Impact: A lower-privilege user could access restricted functions or sensitive resources.

Control requirement ids: FR-002; FR-003; FR-004; FR-005; FR-006; FR-007; FR-008; FR-009; FR-010; FR-011

Evidence ids: E-002; E-003

Residual risk: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

Id: THR-003

Asset: Access grants and revocations

Actor: Hypothetical attacker, privileged insider or failure cause

Scenario: Derived hypothesis: A revoked or changed permission remains effective in a session or enforcement point, allowing access after authorization should have ended.

Impact: A formerly authorized principal could continue using access that is no longer approved.

Control requirement ids: FR-002; FR-003; FR-004; FR-005; FR-006; FR-007; FR-008; FR-009; FR-010; FR-011

Evidence ids: E-002; E-003

Residual risk: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

Id: THR-004

Asset: Administrative security decisions

Actor: Hypothetical attacker, privileged insider or failure cause

Scenario: Derived hypothesis: A malicious or compromised administrator misuses a source-permitted management operation to weaken protection or disrupt legitimate use through the stated administrative workflow.

Impact: Misused administrative authority could undermine protection or interrupt legitimate use.

Control requirement ids: FR-006; FR-007; FR-008; FR-009; FR-010; FR-011

Evidence ids: E-003

Residual risk: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

Id: THR-005

Asset: Integration trust paths

Actor: Hypothetical attacker, privileged insider or failure cause

Scenario: Derived hypothesis: A compromised connected system or integration path supplies forged, altered or missing identity, event or policy data used by the source-defined integration.

Impact: Untrusted integration data could cause incorrect decisions or hide security events.

Control requirement ids: FR-012; FR-013; FR-014; NFR-002; NFR-003; NFR-004; NFR-005

Evidence ids: E-004

Residual risk: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

Id: THR-006

Asset: Security and administrative audit evidence

Actor: Hypothetical attacker, privileged insider or failure cause

Scenario: Derived hypothesis: An attacker or recording failure suppresses or alters source-required audit evidence so that access decisions, security events or admin actions cannot be reconstructed.

Impact: Investigators could lose reliable evidence of the events required by the brief.

Control requirement ids: FR-006; FR-007; FR-008; FR-009; FR-010; FR-011

Evidence ids: E-003

Residual risk: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

Id: THR-007

Asset: Monitoring and security alerts

Actor: Hypothetical attacker, privileged insider or failure cause

Scenario: Derived hypothesis: Suspicious activity evades the source-defined detection workflow, or excessive events obscure actionable alerts before an authorized reviewer can investigate.

Impact: Relevant suspicious activity could remain undetected or receive delayed investigation.

Control requirement ids: FR-006; FR-007; FR-008; FR-009; FR-010; FR-011

Evidence ids: E-003

Residual risk: Unverified planning hypothesis. Linked requirements define intended behavior, not proven prevention. Validate enforcement and residual exposure during design and acceptance review; likelihood and severity are not established.

Assumptions

1. These are defensive planning hypotheses, not observed incidents or approved extra controls. Unrecognized threats and actual implementation effectiveness require human review.

10. Risks

Risks

Id: RISK-001

Description: Derived risk affecting User identities and authenticated access: Unauthorized use of a legitimate identity could expose resources or alter system state.

Likelihood: unknown

Impact: unknown

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: An attacker uses a compromised identity or authenticated session to impersonate an authorized user and exercise that user's permitted operations.

Mitigation: Review impersonation and compromised-identity paths against the stated access duties; confirm any additional identity or session protections with the stakeholder. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Requirement ids: FR-006; FR-007; FR-008; FR-009; FR-010; FR-011; FR-012; FR-013; FR-014; NFR-002; NFR-003; NFR-004; NFR-005

Evidence ids: E-003; E-004

Owner: TBD

Id: RISK-002

Description: Derived risk affecting Role and permission boundaries: A lower-privilege user could access restricted functions or sensitive resources.

Likelihood: unknown

Impact: unknown

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: A principal exploits an incorrect role assignment or permission check to perform operations outside the source-defined authorization boundary.

Mitigation: Test permitted and denied role/resource pairs against the linked authorization duties; review ambiguous permission assignments with the resource owner. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Requirement ids: FR-002; FR-003; FR-004; FR-005; FR-006; FR-007; FR-008; FR-009; FR-010; FR-011

Evidence ids: E-002; E-003

Owner: TBD

Id: RISK-003

Description: Derived risk affecting Access grants and revocations: A formerly authorized principal could continue using access that is no longer approved.

Likelihood: unknown

Impact: unknown

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: A revoked or changed permission remains effective in a session or enforcement point, allowing access after authorization should have ended.

Mitigation: Trace permission changes through subsequent access decisions and any active access; confirm revocation timing and session semantics before baselining them. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Requirement ids: FR-002; FR-003; FR-004; FR-005; FR-006; FR-007; FR-008; FR-009; FR-010; FR-011

Evidence ids: E-002; E-003

Owner: TBD

Id: RISK-004

Description: Derived risk affecting Administrative security decisions: Misused administrative authority could undermine protection or interrupt legitimate use.

Likelihood: unknown

Impact: unknown

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: A malicious or compromised administrator misuses a source-permitted management operation to weaken protection or disrupt legitimate use through the stated administrative workflow.

Mitigation: Review misuse cases for each source-permitted administrative operation and compare its outcomes and audit coverage with the stated management boundary. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Requirement ids: FR-006; FR-007; FR-008; FR-009; FR-010; FR-011

Evidence ids: E-003

Owner: TBD

Id: RISK-005

Description: Derived risk affecting Integration trust paths: Untrusted integration data could cause incorrect decisions or hide security events.

Likelihood: unknown

Impact: unknown

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: A compromised connected system or integration path supplies forged, altered or missing identity, event or policy data used by the source-defined integration.

Mitigation: Review trust assumptions at the specified integration boundaries with missing or altered input fixtures; confirm the required failure handling with the owner. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Requirement ids: FR-012; FR-013; FR-014; NFR-002; NFR-003; NFR-004; NFR-005

Evidence ids: E-004

Owner: TBD

Id: RISK-006

Description: Derived risk affecting Security and administrative audit evidence: Investigators could lose reliable evidence of the events required by the brief.

Likelihood: unknown

Impact: unknown

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: An attacker or recording failure suppresses or alters source-required audit evidence so that access decisions, security events or admin actions cannot be reconstructed.

Mitigation: Compare source-required events with the resulting audit evidence; assess missing and altered-record cases and confirm unprovided protection or retention decisions. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Requirement ids: FR-006; FR-007; FR-008; FR-009; FR-010; FR-011

Evidence ids: E-003

Owner: TBD

Id: RISK-007

Description: Derived risk affecting Monitoring and security alerts: Relevant suspicious activity could remain undetected or receive delayed investigation.

Likelihood: unknown

Impact: unknown

Rationale: This is a planning risk linked to the defensive hypothesis: Derived hypothesis: Suspicious activity evades the source-defined detection workflow, or excessive events obscure actionable alerts before an authorized reviewer can investigate.

Mitigation: Evaluate the stated detection duties with representative positive and negative events; confirm undecided thresholds, alert priorities and investigation responsibilities. Assign a responsible reviewer. Verify the linked canonical obligations against their authored acceptance criteria in an authorized isolated environment. Record gaps and obtain a scope decision before adding any product behavior; preserve explicit exclusions.

Requirement ids: FR-006; FR-007; FR-008; FR-009; FR-010; FR-011

Evidence ids: E-003

Owner: TBD

11. User stories and use cases

User stories and use cases

Id: UC-001

Actor: Authorized administrators

Goal: The system shall allow Authorized administrators to register APIs.

Story: As Authorized administrators, I need the following behavior: The system shall allow Authorized administrators to register APIs.

Preconditions

1. Authorized administrators register APIs

Steps

1. initiate the registration of a new API endpoint

Success outcome: the newly registered API is available in the access management system for use

Requirement ids: FR-002

Evidence ids: E-002

Id: UC-002

Actor: Authorized administrators

Goal: The system shall allow Authorized administrators to define access permissions.

Story: As Authorized administrators, I need the following behavior: The system shall allow Authorized administrators to define access permissions.

Preconditions

1. Authorized administrators define access permissions

Steps

1. define a policy for a named API resource

Success outcome: the named policy definition is available for examination in the system interface

Requirement ids: FR-003

Evidence ids: E-002

Id: UC-003

Actor: Authorized administrators

Goal: The system shall allow Authorized administrators to approve or revoke application access.

Story: As Authorized administrators, I need the following behavior: The system shall allow Authorized administrators to approve or revoke application access.

Preconditions

1. Authorized administrators approve or revoke application access

Steps

1. approve a request for application access

Success outcome: the approved decision is observed in the request status field

Requirement ids: FR-004

Evidence ids: E-002

Id: UC-004

Actor: Authorized administrators

Goal: The system shall allow Authorized administrators to review active API clients.

Story: As Authorized administrators, I need the following behavior: The system shall allow Authorized administrators to review active API clients.

Preconditions

1. Authorized administrators review active API clients

Steps

1. request a list of currently active API clients

Success outcome: the requested list of active API clients is returned for examination

Requirement ids: FR-005

Evidence ids: E-002

12. Verification and acceptance

Tests

Id: TEST-001

Requirement ids: FR-001

Procedure

1. Given: the system receives a request to access an internal API through a student portal, administrative application, research system, or campus service
2. When: the system evaluates the request against defined access policies and applies role-based restrictions

Expected result: Expected: the system returns a response indicating whether access is granted or denied based on the requester's authenticated identity and authorized roles

Evidence to record: Evidence: External test capture of the resulting response

Test type: negative

Id: TEST-002

Requirement ids: FR-002

Procedure

1. Given: Authorized administrators register APIs
2. When: initiate the registration of a new API endpoint

Expected result: Expected: the newly registered API is available in the access management system for use

Evidence to record: Evidence: External test capture of the resulting response

Test type: positive

Id: TEST-003

Requirement ids: FR-003

Procedure

1. Given: Authorized administrators define access permissions
2. When: define a policy for a named API resource

Expected result: Expected: the named policy definition is available for examination in the system interface

Evidence to record: Evidence: External test capture of the inspection record

Test type: inspection

Id: TEST-004

Requirement ids: FR-004

Procedure

1. Given: Authorized administrators approve or revoke application access
2. When: approve a request for application access

Expected result: Expected: the approved decision is observed in the request status field

Evidence to record: Evidence: External test capture of the resulting state

Test type: positive

Id: TEST-005

Requirement ids: FR-005

Procedure

1. Given: Authorized administrators review active API clients
2. When: request a list of currently active API clients

Expected result: Expected: the requested list of active API clients is returned for examination

Evidence to record: Evidence: External test capture of the resulting response

Test type: analysis

Id: TEST-006

Requirement ids: FR-006

Procedure

1. Given: the system receives a controlled identity fixture as a principal for API client authentication
2. When: the system submits the principal to authenticate

Expected result: Expected: the system either accepts or rejects the authentication based on the fixture's validity

Evidence to record: Evidence: External test capture of the resulting response

Test type: negative

Id: TEST-007

Requirement ids: FR-007

Procedure

1. Given: the system receives a controlled role or policy permission fixture
2. When: the system evaluates access based on that fixture

Expected result: Expected: the requested access is allowed or denied in accordance with the fixture's defined permissions

Evidence to record: Evidence: External test capture of the resulting state

Test type: negative

Id: TEST-008

Requirement ids: FR-008

Procedure

1. Given: the system receives a controlled sequence of failed authentication attempts
2. When: the system processes the repeated failures

Expected result: Expected: the system identifies the condition of repeated failed authentication

Evidence to record: Evidence: External test capture of the resulting state

Test type: positive

Id: TEST-009

Requirement ids: FR-009

Procedure

1. Given: the system receives a controlled unauthorized API request
2. When: the system processes the request

Expected result: Expected: the system identifies that the request is unauthorized

Evidence to record: Evidence: External test capture of the resulting state

Test type: positive

Id: TEST-010

Requirement ids: FR-010

Procedure

1. Given: an alert condition is initiated using a controlled event fixture
2. When: the system detects and responds to the condition

Expected result: Expected: a security alert exists in the system as a result of the triggered condition

Evidence to record: Evidence: External test capture of the inspection record

Test type: positive

Id: TEST-011

Requirement ids: FR-011

Procedure

1. Given: the system records access decisions, permission changes, and administrator actions using a controlled fixture

2. When: the system maintains logs for these events

Expected result: Expected: audit logs contain entries reflecting those events as they occur

Evidence to record: Evidence: External test capture of the inspection record

Test type: inspection

Id: TEST-012

Requirement ids: FR-012

Procedure

1. Given: a user accesses the dashboard named in the source obligation
2. When: the system opens the dashboard as a controlled user

Expected result: Expected: the dashboard is displayed or available for use

Evidence to record: Evidence: External test capture of the resulting response

Test type: positive

Id: TEST-013

Requirement ids: FR-013

Procedure

1. Given: a user initiates an exchange with the external identity service named in the source obligation
2. When: the system performs the interoperation as defined by the source obligation

Expected result: Expected: the system observes successful interoperation with that service

Evidence to record: Evidence: External test capture of the resulting response

Test type: positive

Id: TEST-014

Requirement ids: FR-014

Procedure

1. Given: a user initiates use from each campus location named in the source obligation
2. When: the system supports the use as defined by the source obligation

Expected result: Expected: use succeeds at each location

Evidence to record: Evidence: External test capture of the resulting state

Test type: positive

Id: TEST-015

Requirement ids: NFR-001

Procedure

1. Given: A draft acceptance plan for this quality goal: the system shall be secure against unauthorized access and data exfiltration via API endpoints.
2. When: An analyst inspects or reviews that acceptance plan to determine whether measurable targets are defined or remain TBD.

Expected result: Expected: The plan's measurable targets remain TBD or unconfirmed, as no specific thresholds, attack scenarios, or success/failure criteria are provided in the draft plan.

Evidence to record: Evidence: External test capture of the inspection record

Test type: inspection

Id: TEST-016

Requirement ids: NFR-002

Procedure

1. Given: The system shall remain secure under all conditions of use.
2. When: An analyst inspects or reviews that acceptance plan.

Expected result: Expected: The plan's measurable targets remain TBD or unconfirmed.

Evidence to record: Evidence: External test capture of the resulting response

Test type: inspection

Id: TEST-017

Requirement ids: NFR-003

Procedure

1. Given: The system shall remain reliable under all conditions of use.
2. When: An analyst inspects or reviews that acceptance plan.

Expected result: Expected: The plan's measurable targets remain TBD or unconfirmed.

Evidence to record: Evidence: External test capture of the resulting state

Test type: inspection

Id: TEST-018

Requirement ids: NFR-004

Procedure

1. Given: The system shall remain scalable under all conditions of use.
2. When: An analyst inspects or reviews that acceptance plan.

Expected result: Expected: The plan's measurable targets remain TBD or unconfirmed.

Evidence to record: Evidence: External test capture of the inspection record

Test type: inspection

Id: TEST-019

Requirement ids: NFR-005

Procedure

1. Given: The system shall remain manageable under all conditions of use.
2. When: An analyst inspects or reviews that acceptance plan.

Expected result: Expected: The plan's measurable targets remain TBD or unconfirmed.

Evidence to record: Evidence: External test capture of the resulting state

Test type: inspection

Limitations: These verification plans have not been executed; their acceptance outcomes require testing.

13. Glossary

Summary: Source-present terminology; definitions introduce no additional product obligation.

Items

Log

Detail: A collection of event records. This term does not itself require additional logging fields, events or access permissions.

Status: proposed

Evidence ids: E-003

Audit record

Detail: A stored record of an event. Required event scope and retention are determined by the linked source, not this definition.

Status: proposed

Evidence ids: E-003

Policy

Detail: A rule or decision governing permitted actions; its project-specific meaning remains defined by the source requirements.

Status: proposed

Evidence ids: E-003

14. SDLC recommendation and workflow

Selected model: Incremental

Justification: Security decisions benefit from security review and tests throughout delivery (E-002, E-003); monitoring and alert behavior needs validation with operational feedback (E-003); multiple deployment locations offer a staged validation and rollout opportunity (E-004); connected systems need integration verification before broader rollout (E-004). These derived factors support incremental delivery over continuous or sequential models, as staged assurance and repeated integration are more aligned with iterative output than fixed release cycles.

Tradeoffs

1. Recurring delivery requires stakeholder review and backlog refinement; a cycle does not guarantee completeness or remove unresolved decisions.
2. Proposed suitability recommendation; confirm delivery constraints and team capacity before adopting this lifecycle. Missing factors are not assumed.

Phases

Name: Requirements and verification planning

Phase type: planning

Activities

1. Review and baseline the source-defined work group: FR-001: The system shall control access to internal APIs used by student portals, administrative applications, research systems, and campus services.; FR-002: The system shall allow Authorized administrators to register APIs.; FR-003: The system shall allow Authorized administrators to define access permissions.; FR-004: The system shall allow Authorized administrators to approve or revoke application access.; FR-005: The system shall allow Authorized administrators to review active API clients.; FR-006: The system shall authenticate API clients.; FR-007: The system shall enforce role- or policy-based access.; FR-008: The system shall detect repeated failed authentication.; FR-009: The system shall detect unauthorized API requests.; FR-010: The system shall generate security alerts.; FR-011: The system shall maintain audit logs of access decisions, permission changes, and administrator actions.; FR-012: The system shall provide a centralized dashboard.; FR-013: The system shall integrate with existing university identity services.; FR-014: The system shall support multiple campus locations.
2. Review and baseline the source-defined work group: NFR-001: The system shall be secure.; NFR-002: The system shall remain secure.; NFR-003: The system shall remain reliable.; NFR-004: The system shall remain scalable.; NFR-005: The system shall remain manageable.
3. Create the unit, integration, system and acceptance test plan before implementation; retain each authored acceptance criterion.

Roles: Proposed project owner; Proposed development lead; Proposed verification reviewer

Deliverables

1. Versioned requirements baseline
2. Unit, integration, system and acceptance test plan
3. Unresolved-decision record

Entry criteria

1. Authoritative inputs and canonical requirements are available for review.

Exit criteria

1. A human reviewer has recorded the baseline decision and disposition of unresolved scope.

Security checks

1. Review implementation and acceptance evidence against FR-001: The system shall control access to internal APIs used by student portals, administrative applications, research systems, and campus services.
2. Review implementation and acceptance evidence against FR-003: The system shall allow Authorized administrators to define access permissions.
3. Review implementation and acceptance evidence against FR-004: The system shall allow Authorized administrators to approve or revoke application access.
4. Review implementation and acceptance evidence against FR-006: The system shall authenticate API clients.
5. Review implementation and acceptance evidence against FR-007: The system shall enforce role- or policy-based access.
6. Review implementation and acceptance evidence against FR-008: The system shall detect repeated failed authentication.

7. Review implementation and acceptance evidence against FR-010: The system shall generate security alerts.
8. Review implementation and acceptance evidence against FR-011: The system shall maintain audit logs of access decisions, permission changes, and administrator actions.
9. Review implementation and acceptance evidence against NFR-001: The system shall be secure.
10. Review implementation and acceptance evidence against NFR-002: The system shall remain secure.

Human approval: Pending human decision by Proposed project owner on this phase's deliverables and unresolved decisions; no approval is recorded by generation.

Requirement ids: FR-001; FR-002; FR-003; FR-004; FR-005; FR-006; FR-007; FR-008; FR-009; FR-010; FR-011; FR-012; FR-013; FR-014; NFR-001; NFR-002; NFR-003; NFR-004; NFR-005

Name: Incremental delivery cycle

Phase type: iteration

Activities

1. Review and prioritize the backlog for the next iteration without changing source-defined scope.
2. Implement the source-defined work group: FR-001: The system shall control access to internal APIs used by student portals, administrative applications, research systems, and campus services.; FR-002: The system shall allow Authorized administrators to register APIs.; FR-003: The system shall allow Authorized administrators to define access permissions.; FR-004: The system shall allow Authorized administrators to approve or revoke application access.; FR-005: The system shall allow Authorized administrators to review active API clients.; FR-006: The system shall authenticate API clients.; FR-007: The system shall enforce role- or policy-based access.; FR-008: The system shall detect repeated failed authentication.; FR-009: The system shall detect unauthorized API requests.; FR-010: The system shall generate security alerts.; FR-011: The system shall maintain audit logs of access decisions, permission changes, and administrator actions.; FR-012: The system shall provide a centralized dashboard.; FR-013: The system shall integrate with existing university identity services.; FR-014: The system shall support multiple campus locations.
3. Implement the source-defined work group: NFR-001: The system shall be secure.; NFR-002: The system shall remain secure.; NFR-003: The system shall remain reliable.; NFR-004: The system shall remain scalable.; NFR-005: The system shall remain manageable.
4. In an authorized isolated test environment, execute TEST-001: Given: the system receives a request to access an internal API through a student portal, administrative application, research system, or campus service When: the system evaluates the request against defined access policies and applies role-based restrictions Expected: the system returns a response indicating whether access is granted or denied based on the requester's authenticated identity and authorized roles
5. In an authorized isolated test environment, execute TEST-002: Given: Authorized administrators register APIs When: initiate the registration of a new API endpoint Expected: the newly registered API is available in the access management system for use
6. In an authorized isolated test environment, execute TEST-003: Given: Authorized administrators define access permissions When: define a policy for a named API resource Expected: the named policy definition is available for examination in the system interface
7. In an authorized isolated test environment, execute TEST-004: Given: Authorized administrators approve or revoke application access When: approve a request for application access Expected: the approved decision is observed in the request status field

8. In an authorized isolated test environment, execute TEST-005: Given: Authorized administrators review active API clients When: request a list of currently active API clients Expected: the requested list of active API clients is returned for examination
9. In an authorized isolated test environment, execute TEST-006: Given: the system receives a controlled identity fixture as a principal for API client authentication When: the system submits the principal to authenticate Expected: the system either accepts or rejects the authentication based on the fixture's validity
10. In an authorized isolated test environment, execute TEST-007: Given: the system receives a controlled role or policy permission fixture When: the system evaluates access based on that fixture Expected: the requested access is allowed or denied in accordance with the fixture's defined permissions
11. In an authorized isolated test environment, execute TEST-008: Given: the system receives a controlled sequence of failed authentication attempts When: the system processes the repeated failures Expected: the system identifies the condition of repeated failed authentication
12. In an authorized isolated test environment, execute TEST-009: Given: the system receives a controlled unauthorized API request When: the system processes the request Expected: the system identifies that the request is unauthorized
13. In an authorized isolated test environment, execute TEST-010: Given: an alert condition is initiated using a controlled event fixture When: the system detects and responds to the condition Expected: a security alert exists in the system as a result of the triggered condition
14. In an authorized isolated test environment, execute TEST-011: Given: the system records access decisions, permission changes, and administrator actions using a controlled fixture When: the system maintains logs for these events Expected: audit logs contain entries reflecting those events as they occur
15. In an authorized isolated test environment, execute TEST-012: Given: a user accesses the dashboard named in the source obligation When: the system opens the dashboard as a controlled user Expected: the dashboard is displayed or available for use
16. In an authorized isolated test environment, execute TEST-013: Given: a user initiates an exchange with the external identity service named in the source obligation When: the system performs the interoperation as defined by the source obligation Expected: the system observes successful interoperation with that service
17. In an authorized isolated test environment, execute TEST-014: Given: a user initiates use from each campus location named in the source obligation When: the system supports the use as defined by the source obligation Expected: use succeeds at each location
18. In an authorized isolated test environment, execute TEST-015: Given: A draft acceptance plan for this quality goal: the system shall be secure against unauthorized access and data exfiltration via API endpoints. When: An analyst inspects or reviews that acceptance plan to determine whether measurable targets are defined or remain TBD. Expected: The plan's measurable targets remain TBD or unconfirmed, as no specific thresholds, attack scenarios, or success/failure criteria are provided in the draft plan.
19. In an authorized isolated test environment, execute TEST-016: Given: The system shall remain secure under all conditions of use. When: An analyst inspects or reviews that acceptance plan. Expected: The plan's measurable targets remain TBD or unconfirmed.
20. In an authorized isolated test environment, execute TEST-017: Given: The system shall remain reliable under all conditions of use. When: An analyst inspects or reviews that acceptance plan. Expected: The plan's measurable targets remain TBD or unconfirmed.
21. In an authorized isolated test environment, execute TEST-018: Given: The system shall remain scalable under all conditions of use. When: An analyst inspects or reviews that acceptance plan. Expected: The plan's measurable targets remain TBD or unconfirmed.

22. In an authorized isolated test environment, execute TEST-019: Given: The system shall remain manageable under all conditions of use. When: An analyst inspects or reviews that acceptance plan. Expected: The plan's measurable targets remain TBD or unconfirmed.
23. Collect stakeholder feedback; agree its cadence with a human reviewer before scheduling cycles.
24. Return accepted stakeholder feedback and observed defects to the backlog and plan the next iteration.

Roles: Proposed project owner; Proposed development lead; Proposed verification reviewer

Deliverables

1. Requirement-linked implementation increment
2. Recorded test evidence
3. Reviewed feedback and next-iteration backlog

Entry criteria

1. Prior work, source scope and the reviewed test plan are available for iteration planning.

Exit criteria

1. A human reviewer has assessed the increment, test evidence and feedback; unresolved changes return to the next iteration.

Security checks

1. Review implementation and acceptance evidence against FR-001: The system shall control access to internal APIs used by student portals, administrative applications, research systems, and campus services.
2. Review implementation and acceptance evidence against FR-003: The system shall allow Authorized administrators to define access permissions.
3. Review implementation and acceptance evidence against FR-004: The system shall allow Authorized administrators to approve or revoke application access.
4. Review implementation and acceptance evidence against FR-006: The system shall authenticate API clients.
5. Review implementation and acceptance evidence against FR-007: The system shall enforce role- or policy-based access.
6. Review implementation and acceptance evidence against FR-008: The system shall detect repeated failed authentication.
7. Review implementation and acceptance evidence against FR-010: The system shall generate security alerts.
8. Review implementation and acceptance evidence against FR-011: The system shall maintain audit logs of access decisions, permission changes, and administrator actions.
9. Review implementation and acceptance evidence against NFR-001: The system shall be secure.
10. Review implementation and acceptance evidence against NFR-002: The system shall remain secure.

Human approval: Pending human decision by Proposed project owner on this phase's deliverables and unresolved decisions; no approval is recorded by generation.

Requirement ids: FR-001; FR-002; FR-003; FR-004; FR-005; FR-006; FR-007; FR-008; FR-009; FR-010; FR-011; FR-012; FR-013; FR-014; NFR-001; NFR-002; NFR-003; NFR-004; NFR-005

Name: Release and handoff

Phase type: release

Activities

1. Review the exact requirements baseline, implementation links and verification evidence before a release decision.
2. Carry unresolved source decisions into handoff; generated text is not human approval.

Roles: Proposed project owner; Proposed development lead; Proposed verification reviewer

Deliverables

1. Requirements and verification evidence package
2. Pending human release decision
3. Outstanding-decision record

Entry criteria

1. Verification evidence and unresolved decisions are available for human review.

Exit criteria

1. A human has recorded the release/handoff decision for the reviewed content.

Security checks

1. Review implementation and acceptance evidence against FR-001: The system shall control access to internal APIs used by student portals, administrative applications, research systems, and campus services.
2. Review implementation and acceptance evidence against FR-003: The system shall allow Authorized administrators to define access permissions.
3. Review implementation and acceptance evidence against FR-004: The system shall allow Authorized administrators to approve or revoke application access.
4. Review implementation and acceptance evidence against FR-006: The system shall authenticate API clients.
5. Review implementation and acceptance evidence against FR-007: The system shall enforce role- or policy-based access.
6. Review implementation and acceptance evidence against FR-008: The system shall detect repeated failed authentication.
7. Review implementation and acceptance evidence against FR-010: The system shall generate security alerts.
8. Review implementation and acceptance evidence against FR-011: The system shall maintain audit logs of access decisions, permission changes, and administrator actions.
9. Review implementation and acceptance evidence against NFR-001: The system shall be secure.
10. Review implementation and acceptance evidence against NFR-002: The system shall remain secure.

Human approval: Pending human decision by Proposed project owner on this phase's deliverables and unresolved decisions; no approval is recorded by generation.

Requirement ids: FR-001; FR-002; FR-003; FR-004; FR-005; FR-006; FR-007; FR-008; FR-009; FR-010; FR-011; FR-012; FR-013; FR-014; NFR-001; NFR-002; NFR-003; NFR-004; NFR-005

Unknown factors: budget; delivery; failure_consequences; feedback; legacy; regulation; schedule; stability; uncertainty; verification

SDLC rankings and decision evidence

Policy: sequential-sdlc-2.0

Generation profile: sequential-sdlc-generation-2.1

Factors

Name: security_assurance

Value: integrated security review

Evidence ids: E-002; E-003

Basis: derived

Rationale: Security decisions benefit from security review and tests throughout delivery.

Name: operational_validation

Value: monitoring feedback

Evidence ids: E-003

Basis: derived

Rationale: Monitoring and alert behavior needs validation with operational feedback; this does not establish continuous deployment or a release frequency.

Name: deployment_scope

Value: staged rollout opportunity

Evidence ids: E-004

Basis: derived

Rationale: Multiple deployment locations offer a staged validation and rollout opportunity; the rollout plan remains proposed.

Name: integration_assurance

Value: integration validation

Evidence ids: E-004

Basis: derived

Rationale: Connected systems need integration verification before broader rollout; their age, technology and technical uncertainty remain unspecified.

Ranked candidates

Model: Incremental

Score: 66

Reasons: Derived operational_validation (+6 points): Monitoring and alert behavior needs validation with operational feedback; this does not establish continuous deployment or a release frequency. (E-003); Derived deployment_scope (+12 points): Multiple deployment locations offer a staged validation and rollout opportunity; the rollout plan remains proposed. (E-004); Derived integration_assurance (+8 points): Connected systems need integration verification before broader rollout; their age, technology and technical uncertainty remain unspecified. (E-004)

Model: Hybrid

Score: 65

Reasons: Derived security_assurance (+8 points): Security decisions benefit from security review and tests throughout delivery. (E-002, E-003); Derived operational_validation (+5 points): Monitoring and alert behavior needs validation with operational feedback; this does not establish continuous deployment or a release frequency. (E-003); Derived deployment_scope (+8 points): Multiple deployment locations offer a staged validation and rollout opportunity; the rollout plan remains proposed. (E-004); Derived integration_assurance (+4 points): Connected systems need integration verification before broader rollout; their age, technology and technical uncertainty remain unspecified. (E-004)

Model: DevSecOps

Score: 63

Reasons: Derived security_assurance (+12 points): Security decisions benefit from security review and tests throughout delivery. (E-002, E-003); Derived operational_validation (+8 points): Monitoring and alert behavior needs validation with operational feedback; this does not establish continuous deployment or a release frequency. (E-003); Derived deployment_scope (+3 points): Multiple deployment locations offer a staged validation and rollout opportunity; the rollout plan remains proposed. (E-004)

Model: Spiral

Score: 51

Reasons: Derived security_assurance (+5 points): Security decisions benefit from security review and tests throughout delivery. (E-002, E-003); Derived integration_assurance (+6 points): Connected systems need integration verification before broader rollout; their age, technology and technical uncertainty remain unspecified. (E-004)

Model: Agile

Score: 40

Reasons: No differentiating input evidence

Model: V-Model

Score: 40

Reasons: No differentiating input evidence

Model: Waterfall

Score: 40

Reasons: No differentiating input evidence

Evidence register

Id: E-001

Source: description

Quote: Design a secure university API access management system that controls access to internal APIs used by student portals, administrative applications, research systems, and campus services.

Id: E-002

Source: description

Quote: Authorized administrators should be able to register APIs, define access permissions, approve or revoke application access, and review active API clients.

Id: E-003

Source: description

Quote: The system should authenticate API clients, enforce role- or policy-based access, detect repeated failed authentication and unauthorized API requests, generate security alerts, and maintain audit logs of access decisions, permission changes, and administrator actions.

Id: E-004

Source: description

Quote: The platform should provide a centralized dashboard, integrate with existing university identity services, support multiple campus locations, and remain secure, reliable, scalable, and manageable.

Source references

kb-c1e0239af9dd46bd:1 - 03_OWASP_CheatSheets/107_OWASP_Zero_Trust_Architecture_Cheat_Sheet.md

Source document id: kb-c1e0239af9dd46bd

Chunk index: 1

Page or section: text chunk 2

Relevance score: 0.7381

Sha256: f5fe6d1e1cfefc05da1b1b9773acee6b7e9d156f4aa69ab0a14a7a1adfd2a8ef

kb-c1e0239af9dd46bd:9 - 03_OWASP_CheatSheets/107_OWASP_Zero_Trust_Architecture_Cheat_Sheet.md

Source document id: kb-c1e0239af9dd46bd

Chunk index: 9

Page or section: text chunk 10

Relevance score: 0.7297

Sha256: f5fe6d1e1cfefc05da1b1b9773acee6b7e9d156f4aa69ab0a14a7a1adfd2a8ef

kb-ecd06e0e85ebe229:0 - 03_OWASP_CheatSheets/038_OWASP_Authorization_Cheat_Sheet.md

Source document id: kb-ecd06e0e85ebe229

Chunk index: 0

Page or section: text chunk 1

Relevance score: 0.7196

Sha256: e78a10eb9759a1fc7593ba1fc89a05b017e7e795ac16ad5496bdba86138d891f

kb-ecd06e0e85ebe229:7 - 03_OWASP_CheatSheets/038_OWASP_Authorization_Cheat_Sheet.md

Source document id: kb-ecd06e0e85ebe229

Chunk index: 7

Page or section: text chunk 8

Relevance score: 0.7151

Sha256: e78a10eb9759a1fc7593ba1fc89a05b017e7e795ac16ad5496bdba86138d891f

kb-ecd06e0e85ebe229:16 - 03_OWASP_CheatSheets/038_OWASP_Authorization_Cheat_Sheet.md

Source document id: kb-ecd06e0e85ebe229

Chunk index: 16

Page or section: text chunk 17

Relevance score: 0.7264

Sha256: e78a10eb9759a1fc7593ba1fc89a05b017e7e795ac16ad5496bdba86138d891f

kb-0150d5352d0ec304:15 - 03_OWASP_CheatSheets/036_OWASP_Authentication_Cheat_Sheet.md

Source document id: kb-0150d5352d0ec304

Chunk index: 15

Page or section: text chunk 16

Relevance score: 0.7227

Sha256: b1d318a57f742d12b57bccda3153873653652c767038c5ca3d9d74350819f303

kb-0150d5352d0ec304:22 - 03_OWASP_CheatSheets/036_OWASP_Authentication_Cheat_Sheet.md

Source document id: kb-0150d5352d0ec304

Chunk index: 22

Page or section: text chunk 23

Relevance score: 0.7244

Sha256: b1d318a57f742d12b57bccda3153873653652c767038c5ca3d9d74350819f303

Validation findings

Code: human_semantic_review_required

Severity: warning

Section: document

Message: Review completeness, actor permissions, contradictions and citation applicability; schema and link checks do not prove semantic correctness.

Human review history

None recorded.

AI drafting record

Requested model: cybersrs-qwen3-4b-ft:latest

Actual models used: cybersrs-qwen3-4b-ft:latest; qwen3:4b-instruct-2507-q4_K_M

Section models

Introduction: cybersrs-qwen3-4b-ft:latest

Functional requirements: cybersrs-qwen3-4b-ft:latest; qwen3:4b-instruct-2507-q4_K_M

Non-functional requirements: cybersrs-qwen3-4b-ft:latest

Compliance and policy applicability matrix: cybersrs-qwen3-4b-ft:latest

Architecture: cybersrs-qwen3-4b-ft:latest

Threats: cybersrs-qwen3-4b-ft:latest

Risks: cybersrs-qwen3-4b-ft:latest

User stories and use cases: cybersrs-qwen3-4b-ft:latest

Verification and acceptance: cybersrs-qwen3-4b-ft:latest

Glossary: cybersrs-qwen3-4b-ft:latest

SDLC recommendation and workflow: cybersrs-qwen3-4b-ft:latest

Prompt version: sequential-1.39

Requirements traceability matrix

Requirement	Evidence / sources	Stories / tests / SDLC
FR-001	E-001	TEST-001, Requirements and verification planning, Incremental delivery cycle, Release and handoff
FR-002	E-002	UC-001, TEST-002, Requirements and verification planning, Incremental delivery cycle, Release and handoff
FR-003	E-002	UC-002, TEST-003, Requirements and verification planning, Incremental delivery cycle, Release and handoff
FR-004	E-002	UC-003, TEST-004, Requirements and verification planning, Incremental delivery cycle, Release and handoff
FR-005	E-002	UC-004, TEST-005, Requirements and verification planning, Incremental delivery cycle, Release and handoff
FR-006	E-003	TEST-006, Requirements and verification planning, Incremental delivery cycle, Release and handoff
FR-007	E-003	TEST-007, Requirements and verification planning, Incremental delivery cycle, Release and handoff
FR-008	E-003	TEST-008, Requirements and verification planning, Incremental delivery cycle, Release and handoff
FR-009	E-003	TEST-009, Requirements and verification planning, Incremental delivery cycle, Release and handoff
FR-010	E-003	TEST-010, Requirements and verification planning, Incremental delivery cycle, Release and handoff
FR-011	E-003	TEST-011, Requirements and verification planning, Incremental delivery cycle, Release and handoff
FR-012	E-004	TEST-012, Requirements and verification planning, Incremental delivery cycle, Release and handoff
FR-013	E-004	TEST-013, Requirements and verification planning, Incremental delivery cycle, Release and handoff
FR-014	E-004	TEST-014, Requirements and verification planning, Incremental delivery cycle, Release and handoff

Requirement	Evidence / sources	Stories / tests / SDLC
NFR-001	E-001	TEST-015, Requirements and verification planning, Incremental delivery cycle, Release and handoff
NFR-002	E-004	TEST-016, Requirements and verification planning, Incremental delivery cycle, Release and handoff
NFR-003	E-004	TEST-017, Requirements and verification planning, Incremental delivery cycle, Release and handoff
NFR-004	E-004	TEST-018, Requirements and verification planning, Incremental delivery cycle, Release and handoff
NFR-005	E-004	TEST-019, Requirements and verification planning, Incremental delivery cycle, Release and handoff

Model: cybersrs-qwen3-4b-ft:latest + qwen3:4b-instruct-2507-q4_K_M; prompt: sequential-1.39